ChatGPT

Missus Tom v0.4.7 Code-Base Audit

Deliverable

The completed audit is available as a text-layer PDF designed to remain readable both visually and through programmatic/Codex extraction:

[Download the Missus Tom v0.4.7 Code-Base Audit PDF]

The audit is pinned specifically to **tag** `v0.4.7` **at commit** `e633b0a6aec3adcea0f28bd0f0be9d13022e70f1`, rather than a later state of the default branch. The exact commit also had successful CI and Linux-release workflow runs on October 26, 2026.

The PDF contains **thirteen prioritized findings**, each with a stable finding ID, priority, category, confidence, impact analysis, exact repository file and source-line range, the causative code excerpt, remediation guidance, and a concrete verification/acceptance test.

Highest-priority findings

P1-01 — Local API trust boundary. The packaged backend listens on predictable loopback port `8765`, while state-changing operations such as backend shutdown and run cancellation have no per-launch authentication token or comparable request-ownership control. CORS restricts browser response access but is not authentication for local callers. The report recommends a cryptographically random per-launch host↔sidecar secret, custom authentication header, preferably an ephemeral port, and defense-in-depth Origin/Fetch-Metadata checks. OWASP likewise recommends explicit defenses around state-changing requests and documents custom request headers and origin validation as CSRF controls. [1]

P1-02 — Custom workflow selection can fail open. `PipelineSourceService._read_active()` converts both filesystem errors and malformed activation JSON into `None`; downstream code interprets `None` as "use the official workflow." Thus corrupt or unreadable activation metadata can silently change the workflow that executes rather than stopping execution.

P1-03 — Ambiguous biological metadata matching. The generic metadata path contains dataset-specific normalization for `P50Large_`, leading `n` identifiers, hyphen/underscore changes and `_S<number>` suffixes. After normalization, collisions are automatically resolved by preferring one metadata row and issuing a warning rather than making the ambiguity blocking. Because these rows carry experimental-design fields, the report treats this as a scientific-correctness risk and recommends explicit migration profiles plus mandatory user resolution of many-to-one mappings.

P1-04 — ONT environments are not fully reproducible. Bulk RNA-seq installation uses an explicit lock path, whereas ONT takes the solver-based branch. ONT specifications leave packages such as `samtools`, `htslib`, `r-base`, Python minor versions, and the subsequently installed R/Bioconductor stack

unpinned. The recommended fix is an explicit ONT lock with exact artifacts/hashes and recorded lock identity in run provenance.

P1-05 — Release builds are only partially reproducible. Backend runtime dependencies are specified using broad compatible ranges, while the Linux release workflow installs a moving Rust `stable` toolchain and resolves Python dependencies from the network during the build. pip's official repeatable-install guidance recommends exact version pinning and supports hash verification for stronger reproducibility and integrity. [2] The repository already does one important supply-chain measure correctly: GitHub Actions are pinned to commit SHAs, which matches GitHub's secure-use recommendation. [3]

P1-06 — Dependency-vulnerability findings are not a release gate. The exact v0.4.7 CI execution reported **two high-severity npm vulnerabilities**, yet the overall application-check job passed. The principal project check script performs linting, tests, type checking and builds but has no explicit dependency-vulnerability gate. The PDF deliberately does **not** claim those advisories are exploitable, because the CI summary did not identify their packages or runtime reachability; it instead marks them for immediate triage and recommends a policy-driven vulnerability stage.

P1-07 — Green CI does not guarantee execution of the principal R scientific regression suite or native containment tests. The R-analysis test module is skipped wholesale when `Rscript`, DESeq2, tximport or ggplot2 are unavailable. Linux containment tests similarly self-skip when the hosted environment cannot establish the required systemd/cgroup capabilities, and the controlled OOM probe requires an explicit opt-in variable. On the audited CI run, the backend suite reported **412 passed and 24 skipped**. The report recommends separate mandatory R/Bioconductor and native-cgroup CI jobs where required tests are forbidden from silently skipping.

Reliability, performance, and maintainability findings

The medium-priority findings include **unbounded renderer retention of complete command logs** despite the visible preview being capped; `fullTextRef.current` continues accumulating every chunk. The recommended architecture leaves the full append-only log in the backend/native layer and keeps only a bounded renderer tail.

The **resource monitor fails open when its inspectors throw exceptions**: host and disk probe failures are converted to `None`, which can leave no unhealthy reason and therefore make an unknown resource state appear healthy. The proposed correction distinguishes “healthy” from “measurement unavailable,” retains pressure-debounce state across unknown samples, and escalates sustained loss of monitoring.

The recent-validation cache fingerprints referenced files using **path, size and mtime**, rather than content identity. The report classifies this as a bounded validation-cache integrity weakness rather than a proven run-execution defect, and recommends stronger metadata identity or hashes for critical references.

A concrete diagnostics bug occurs because `resolveApiBaseUrl()` constructs useful packaged-sidecar startup diagnostics—including the startup log—but `apiRequest()` subsequently replaces that failure with a generic instruction to start a backend on development port `8000`; the packaged sidecar uses `8765`.

The report also identifies **NewProjectWizard's manually synchronized state architecture** as a maintainability and future state-consistency risk. The component owns a large number of interdependent `useState` values, while pipeline/start-stage transitions manually clear subsets of them. React's own guidance notes that reducers are useful when many state updates are spread across handlers because they centralize transitions and improve debugging and testability. [4]

Finally, the low-priority cancellation finding documents an **already-aborted** `AbortSignal` **race** in `resolveWithin()`: it installs an abort listener but does not first test whether the one-shot abort has already occurred.

Positive controls already present

The codebase has substantial strengths that materially reduce risk. The dependency installer validates Micromamba hashes, checks the extracted executable, and applies path/link safety checks when extracting Dorado archives. The release workflow uses SHA-pinned GitHub Actions, consistent with GitHub's hardened-workflow guidance. [3]

Core persistence code also uses atomic replacement patterns in important state-writing paths, and the repository contains extensive work around process containment, run recovery, admission locking, dependency verification, typed error conditions, frontend contracts, and execution-state consistency. The principal check script runs Ruff, formatting verification, mypy, backend pytest, desktop lint/tests/type checking/build verification, ONT tests, and shell syntax checks.

The report therefore does **not** characterize v0.4.7 as an immature codebase. Its most consequential remaining weaknesses are concentrated at mature-application boundaries: **who is authorized to control the local service, exactly which workflow and dependency graph executed, how ambiguous biological identity is resolved, and whether a green release truly exercised the required scientific paths.**

Verification context and limitations

All source-level findings are tied to the immutable v0.4.7 commit rather than inferred from present-day `main`. The exact commit had successful CI and Linux-release workflows.

A direct network `git clone` could not be completed inside the controlled audit runtime because external git/DNS access was unavailable there. Accordingly, the PDF does **not** falsely claim a second independent local execution of Ruff, mypy, pytest, npm, R, Nextflow, Tauri packaging, or security scanners. Instead, it distinguishes direct source findings from observations taken from the repository's exact-commit GitHub Actions execution.

The report also avoids overstating what was not established: it does not claim remote code execution through the loopback issue; it does not claim the two npm advisories are runtime-exploitable without advisory/package triage; and it does not claim scientific equivalence on real datasets where the required R execution environment was absent from the reviewed hosted CI job.

Download the completed PDF audit

---

1 Cross-Site Request Forgery Prevention - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html?utm_source=chatgpt.com

2 Repeatable Installs - pip documentation v26.2.2
https://pip.pypa.io/en/stable/topics/repeatable-installs/?utm_source=chatgpt.com

3 Secure use reference - GitHub Enterprise Server 3.20 Docs
https://docs.github.com/en/enterprise-server%403.20/actions/reference/security/secure-use?utm_source=chatgpt.com

4 useReducer – React
https://react.dev/reference/react/useReducer?utm_source=chatgpt.com